

KRİPTOQRAFIYA KURSU

Mühazirə 14

MD5, SHA-1, SHA-2

Bu mühazirə ən geniş yayılmış heş funksiyalarını — MD5, SHA-1 və SHA-2 ailəsini — onların quruluşunu, təhlükəsizlik xüsusiyyətlərini, onlara qarşı aparılmış hücumları və hazırkı vəziyyətini əhatə edir.

June 26, 2026

Contents

1	Mühazirənin məqsədləri	2
2	Giriş	2
3	MD5 Heş Funksiyası	2
3.1	MD5-in Tarixi və Yaranması	2
3.2	MD5-in Daxili Quruluşu və İş Mexanizmi	3
3.2.1	Registrlərin Yenilənmə Təhlükələri	3
3.2.2	Mərhələlər üzrə Məntiqi Funksiyalar	3
3.2.3	Sola Dövrü Sürüşdürmə (ROTL)	4
3.3	MD5-ə qarşı hücumlar	4
3.4	MD5-in praktik sındırılması	5
3.5	MD5-in hazırkı vəziyyəti	5
4	SHA-1 heş funksiyası	5
4.1	SHA-1-in tarixi və yaranması	5
4.2	SHA-1-in Quruluşu	6
4.3	SHA-1-ə qarşı hücumlar	7
4.4	SHattered hücumu (2017)	7
4.5	SHA-1-in hazırkı vəziyyəti	8
5	SHA-2 ailəsi	8
5.1	SHA-2-nin tarixi və yaranması	8
5.2	SHA-2 variantları	8
5.3	SHA-256-nın quruluşu	8
5.4	SHA-2-nin təhlükəsizliyi	9
6	Heş funksiyalarının müqayisəsi	10
6.1	Təhlükəsizlik müqayisəsi	10
6.2	Performans müqayisəsi	10
6.3	Tətbiq sahələrinə görə seçim	11
7	Praktik tövsiyələr	12
8	Nümunə məsələlər və çalışmalar	12
9	Çalışmaların həlli	14
10	Xülasə	14
11	Əlavə oxu üçün materiallar	15

1 Mühazirənin məqsədləri

Bu mühazirəni bitirdikdən sonra tələbə:

- MD5, SHA-1 və SHA-2 heş funksiyalarının tarixini və xüsusiyyətlərini izah edə biləcək.
- MD5 və SHA-1-ə qarşı aparılmış hücumların mahiyyətini başa düşəcək.
- SHA-256 və SHA-512-nin daxili quruluşunu təhlil edə biləcək.
- Müxtəlif heş funksiyalarının təhlükəsizlik və performans xüsusiyyətlərini müqayisə edə biləcək.
- Müasir tətbiqlər üçün uyğun heş funksiyasını seçə biləcək.

2 Giriş

Heş funksiyaları müasir kriptografiyanın ayrılmaz hissəsidir. Əvvəlki mühazirədə heş funksiyalarının nəzəri əsaslarını, təhlükəsizlik xüsusiyyətlərini və quruluşlarını öyrəndik. Bu mühazirədə ən geniş yayılmış heş funksiyalarını — **MD5**, **SHA-1** və **SHA-2** ailəsini — ətraflı şəkildə tədqiq edəcəyik.

Bu heş funksiyalarının hər biri öz dövrünün standartı olmuş, geniş tətbiq sahələrində istifadə edilmişdir. Lakin zaman keçdikcə onların bəzilərində ciddi təhlükəsizlik zəiflikləri aşkar edilmişdir. Bu mühazirədə hər bir heş funksiyasının quruluşunu, güclü və zəif tərəflərini, onlara qarşı aparılmış hücumları və hazırkı vəziyyətini öyrənəcəyik.

Əsas suallar

- MD5 niyə bu qədər uzun müddət istifadə olundu və niyə indi təhlükəsiz deyil?
- SHA-1-i sındırmaq üçün hansı hücumlar aparıldı və SHAttered nədir?
- SHA-256 və SHA-512 arasında hansı fərqlər var?
- Hansı heş funksiyaları müasir tətbiqlər üçün təhlükəsizdir?
- Köhnə heş funksiyalarından yeni sistemlərə keçid necə aparılmalıdır?

3 MD5 Heş Funksiyası

3.1 MD5-in Tarixi və Yaranması

MD5 (*Message Digest 5*) — **Ron Rivest** tərəfindən 1991-ci ildə hazırlanmış 128-bit çıxışlı heş funksiyasıdır. MD5, əvvəlki versiyalar olan MD2 (1989) və MD4-ün (1990) təkmilləşdirilmiş variantıdır.

MD5 tez bir zamanda geniş yayıldı və İnternetdə ən populyar heş funksiyasına çevrildi. O, fayl bütövlüyünün yoxlanması, proqram təminatı yükləmələri, parol saxlanması və rəqəmsal imzalar kimi müxtəlif sahələrdə geniş tətbiq olunmuşdur.

Heş funksiyası	İl	Müəllif	Çıxış uzunluğu
MD2	1989	Ron Rivest	128-bit
MD4	1990	Ron Rivest	128-bit
MD5	1991	Ron Rivest	128-bit

Table 1: MD ailəsinin inkişaf tarixi

3.2 MD5-in Daxili Quruluşu və İş Mexanizmi

MD5 algoritmi **Merkel-Damqord quruluşuna** əsaslanır və mesajın hər 512-bitlik bloku üçün 64 raunddan ibarət transformasiya tətbiq edir. Alqoritmin daxili vəziyyəti (state) dörd ədəd 32-bitlik registrdən (A, B, C, D) ibarətdir.

3.2.1 Registrlərin Yenilənmə Tənlikləri

MD5-də hər bir addımda dörd registrdən biri yenilənir. Bir tam dövr (4 addım) ərzində registrlər ardıcıl olaraq aşağıdakı riyazi tənliklərlə transformasiya olunur:

1. $A = B + \text{ROTL}_s(A + f(B, C, D) + M_i + K_i)$
2. $D = A + \text{ROTL}_s(D + f(A, B, C) + M_j + K_j)$
3. $C = D + \text{ROTL}_s(C + f(D, A, B) + M_k + K_k)$
4. $B = C + \text{ROTL}_s(B + f(C, D, A) + M_l + K_l)$

Burada istifadə olunan əməliyyatların və simvolların mənası:

- A, B, C, D : 32-bitlik registrlər. Hər addımda onlardan biri (məsələn, birinci addımda A , dördüncü addımda B) hədəf registr kimi yenilənir.
- f : Raundun nömrəsindən asılı olaraq dəyişən qeyri-xətti məntiq funksiyası.
- M_i, M_j, M_k, M_l : Mesajın 512-bitlik blokundan götürülmüş 32-bitlik alt-bloklar.
- K_i : Hər bir raund üçün unikal olan və sinus funksiyasına əsasən təyin edilən 32-bitlik sabit.
- $\text{ROTL}_s(x)$: x dəyərinin bitlərini s mövqe sola dövrə sürüşdürən (Rotate Left) əməliyyat.

3.2.2 Mərhələlər üzrə Məntiqi Funksiyalar

MD5 cəmi 64 raunddan ibarətdir və bu raundlar hər biri 16 raund olmaqla 4 əsas mərhələyə bölünür. Hər mərhələdə fərqli bir qeyri-xətti f funksiyası istifadə olunur:

1. 1–16-cı raundlar (F funksiyası):

$$F(X, Y, Z) = (X \wedge Y) \vee (\neg X \wedge Z)$$

Bu funksiya X bitinə əsasən seçim edir: əgər X doğrudursa Y , deyilsə Z bitini götürür.

2. 17–32-ci raundlar (G funksiyası):

$$G(X, Y, Z) = (X \wedge Z) \vee (Y \wedge \neg Z)$$

Bu funksiya Z bitinə əsasən seçim edir: əgər Z doğrudursa X , deyilsə Y bitini götürür.

3. 33–48-ci raundlar (H funksiyası):

$$H(X, Y, Z) = X \oplus Y \oplus Z$$

Bu, bit-bit XOR əməliyyatıdır və daxili vəziyyətin xətti şəkildə qarışdırılmasını təmin edir.

4. 49–64-cü raundlar (I funksiyası):

$$I(X, Y, Z) = Y \oplus (X \vee \neg Z)$$

Bu funksiya daha mürəkkəb qeyri-xətti əlaqə yaradaraq diferensial analizə qarşı dayanıqlığı artırır.

3.2.3 Sola Dövri Sürüşdürmə (ROTL)

ROTL əməliyyatı MD5-in sürətli və effektiv olmasını təmin edən əsas bit əməliyyatıdır. 32-bitlik arifmetikada o aşağıdakı kimi təyin olunur:

$$\text{ROTL}_s(x) = (x \ll s) \vee (x \gg (32 - s))$$

Burada bitlər sola s qədər sürüşdürülür və soldan çıxan bitlər sağ tərəfə əlavə olunur. Bu, heç bir bitin itməməsini və bütün bitlərin sonrakı hesablamalara təsir etməsini təmin edir.

3.3 MD5-ə qarşı hücumlar

MD5-ə qarşı ilk ciddi kriptografik hücumlar 1990-cı illərin ortalarında başlamışdır (Stinson and Paterson, 2018). Bu hücumlar zaman keçdikcə funksiyanın nəzəri davamlılığını tamamilə sarsıtmışdır:

- **1993-cü il:** B. den Boer və A. Bosselaers MD5-in sıxışdırma funksiyasında toqquşma tapdılar. Bu, tam heş funksiyasında toqquşma olmasa da, ilk ciddi signal idi.
- **1996-cı il:** Hans Dobbertin MD5-in sıxışdırma funksiyasında toqquşma taparaq funksiyanın tam versiyasının da təhlükəsiz olmaya biləcəyini göstərdi.
- **2004-cü il:** Xiaoyun Wang və digərləri MD5-də tam toqquşma tapdıqlarını elan etdilər (Wang and Yu, 2005).

Teorem 3.1 (MD5-in toqquşma mürəkkəbliyi). *2004-cü ildə Wang və digərləri göstərdilər ki, MD5 üçün toqquşma tapmaq mürəkkəbliyi ad günü paradoksuna əsaslanan 2^{64} əməliyyatdan 2^{39} əməliyyata qədər endirilə bilər (Wang and Yu, 2005).*

3.4 MD5-in praktik sındırılması

2004-cü ildən sonra aparılan tədqiqatlar MD5-in sındırılmasını laboratoriya şəraitindən praktik sferaya keçirdi (Stinson and Paterson, 2018):

- **2005-ci il:** Vlastimil Klima MD5-də cəmi bir neçə saat ərzində toqquşma tapmağı mümkün edən alqoritm hazırladı.
- **2007-ci il:** Marc Stevens toqquşma tapmaq üçün tələb olunan müddəti saniyələr səviyyəsinə endirdi.
- **2008-ci il:** Alexander Sotirov və digərləri eyni MD5 heşinə malik fərqli SSL sertifikatları yaratmağa nail oldular (Stevens et al., 2009).
- **2012-ci il:** "Flame" zərərli proqram təminatı MD5-in toqquşma zəifliyindən istifadə edərək Microsoft-un rəsmi yeniləmə sertifikatlarını saxtalaşdırdı.

MD5 hazırda toqquşmaya qarşı tamamilə dayanıqsız hesab olunur. Rəqəmsal imzalar və ya bütövlüyün yoxlanılması tələb olunan yeni sistemlərdə MD5-in istifadəsi qətiyyən tövsiyə edilmir.

3.5 MD5-in hazırkı vəziyyəti

Bu gün MD5 **tamamilə sındırılmış** hesab edilir və təhlükəsizlik tələb edən heç bir sistemdə istifadə edilməməlidir. MD5-in rəqəmsal imzaların saxtalaşdırılmasına və sertifikatların təkrarlanmasına yol açması onu etibarsız edir.

- **ABŞ CERT:** 2008-ci ildə MD5-in istifadəsini rəsmən tövsiyə etmədiyini bildirdi.
- **NIST:** Federal İnformasiya Emalı Standartlarından (FIPS) MD5-i çıxardı.
- **IETF:** RFC 6151 sənədində MD5-in təhlükəsizlik problemləri və onun artıq təhlükəsiz hesab edilmədiyini rəsmən sənədləşdirildi.
- **Platformalar:** Google Chrome, Mozilla Firefox və Microsoft Edge kimi müasir brauzerlər MD5 əsaslı rəqəmsal sertifikatları qəbul etmirlər.

MD5 hazırda yalnız **qeyri-kriptoqrafik** tətbiqlərdə, məsələn, məlumat bütövlüyünün qeyri-kritik yoxlanılması (checksum) və ya verilənlər bazasında sürətli indeksləşdirmə üçün istifadə oluna bilər. Lakin məlumat bütövlüyünün pozulması kritik nəticələrə yol açmaqla bəzi hallarda MD5-dən qaçınmaq lazımdır.

4 SHA-1 heş funksiyası

4.1 SHA-1-in tarixi və yaranması

SHA (*Secure Hash Algorithm*) — **ABŞ Milli Təhlükəsizlik Agentliyi (NSA)** tərəfindən hazırlanmış və **Milli Standartlar və Texnologiya İnstitutu (NIST)** tərəfindən yayımlanmış heş funksiyaları ailəsidir.

- **SHA-0:** 1993-cü ildə FIPS PUB 180 standartı olaraq yayımlanmışdır. Lakin daxili zəifliklərin aşkar edilməsi səbəbindən 1995-ci ildə geri çəkilmişdir.
- **SHA-1:** 1995-ci ildə FIPS PUB 180-1 olaraq təqdim edilmişdir. Bu versiyada SHA-0-dakı müəyyən struktur zəiflikləri düzəldilmişdir.
- **Çıxış uzunluğu:** 160-bit (5 ədəd 32-bitlik söz).

SHA-1 alqoritmi MD5-dəki zəifliklərin fonunda sürətlə populyarlıq qazanmış və İnternet infrastrukturunda ən çox istifadə olunan heş funksiyasına çevrilmişdir. O, uzun müddət TLS/SSL sertifikatlarının yaradılmasında, SSH protokollarında, PGP rəqəmsal imzalarında, Git versiya idarəetmə sistemində və bir çox digər kritik tətbiqlərdə əsas komponent kimi istifadə olunmuşdur.

4.2 SHA-1-in Quruluşu

SHA-1 alqoritmi də **Merkli-Damqord quruluşuna** əsaslanır (Stinson and Paterson, 2018). Onun əsas texniki parametrləri aşağıdakılardır:

- **Çıxış uzunluğu:** 160-bit (5×32 -bit söz: A, B, C, D, E).
- **Blok ölçüsü:** 512-bit (16×32 -bit söz).
- **Daxili vəziyyət (Internal State):** 5×32 -bit söz (A, B, C, D, E).
- **Raund sayı:** 80 raund (hər biri 20 raunddan ibarət 4 mərhələ).

SHA-1-də hər raundda aşağıdakı transformasiya əməliyyatları yerinə yetirilir (NIST, 1995):

$$\begin{aligned}
 T &= \text{ROTL}_5(A) + f_t(B, C, D) + E + W_t + K_t \\
 E &= D \\
 D &= C \\
 C &= \text{ROTL}_{30}(B) \\
 B &= A \\
 A &= T
 \end{aligned}$$

Burada f_t raundun nömrəsindən (t) asılı olan qeyri-xətti məntiq funksiyasıdır:

- $0 \leq t \leq 19$ (**Mərhələ 1**): $f_t(B, C, D) = (B \wedge C) \vee (\neg B \wedge D)$
- $20 \leq t \leq 39$ (**Mərhələ 2**): $f_t(B, C, D) = B \oplus C \oplus D$
- $40 \leq t \leq 59$ (**Mərhələ 3**): $f_t(B, C, D) = (B \wedge C) \vee (B \wedge D) \vee (C \wedge D)$
- $60 \leq t \leq 79$ (**Mərhələ 4**): $f_t(B, C, D) = B \oplus C \oplus D$

Mesajın genişləndirilməsi (W_t): İlkin 512-bitlik mesaj bloku 16 ədəd 32-bitlik sözdən ibarət olur. Bu blok aşağıdakı qayda ilə 80 raunda çatdırılmaq üçün genişləndirilir:

$$W_t = \begin{cases} M_t & 0 \leq t \leq 15 \\ \text{ROTL}_1(W_{t-3} \oplus W_{t-8} \oplus W_{t-14} \oplus W_{t-16}) & 16 \leq t \leq 79 \end{cases}$$

Burada ROTL_1 əməliyyatı SHA-0 ilə SHA-1 arasındakı fundamental fərqdır və alqoritmi diferensial kriptanalizə qarşı daha dayanıqlı edir.

4.3 SHA-1-ə qarşı hücumlar

SHA-1 alqoritminə qarşı kriptografik hücumlar zaman keçdikcə nəzəri səviyyədən praktik sındırılma səviyyəsinə qədər inkişaf etmişdir (Stinson and Paterson, 2018):

- **2005-ci il:** Rijmen və Oswald SHA-1-in 53 raundluq azaldılmış versiyasına qarşı uğurlu hücum metodikasını təklif etdilər.
- **2005-ci il:** Wang, Yin və Yu tərəfindən SHA-1-in tam 80 raundluq versiyasına qarşı 2^{69} mürəkkəbliyində olan ilk nəzəri toqquşma hücumu təqdim edildi.
- **2011-ci il:** Marc Stevens SHA-1 üçün toqquşma tapmaq mürəkkəbliyini 2^{60} əməliyyat səviyyəsinə endirərək alqoritmın zəifliyini daha da qabartdı.
- **2015-ci il:** Pierre Karpman, Thomas Peyrin və Marc Stevens SHA-1-in 76 addımlı azaldılmış sıxışdırma funksiyası üçün praktik *free-start* toqquşma göstərdilər. Bu nəticə tam heş funksiyası üçün praktik toqquşma olmasa da, alqoritmın daxili strukturunun artıq etibarlı olmadığını sübut etdi.

4.4 SHAttered hücumu (2017)

2017-ci ildə **Google** və **CWI Amsterdam** tədqiqatçıları SHA-1 üçün ilk praktik toqquşmanı nümayiş etdirdilər. Bu tarixi hücum **SHAttered** adlandırılmışdır.

Teorem 4.1 (SHAttered hücumu). *SHAttered hücumu SHA-1 üçün tam toqquşma tapmaq mürəkkəbliyini 2^{63} əməliyyat səviyyəsinə endirmişdir. Bu hesablamanı həyata keçirmək üçün təxminən 110 il GPU vaxtı (və ya 6500 CPU il) tələb olunur.*

Nümunə 4.1 (SHAttered toqquşma nümunəsi). *Tədqiqatçılar məzmunu fərqli olan (məsələn, biri göy, digəri isə qırmızı fonlu) iki fərqli PDF sənədi hazırlamışlar. Bu sənədlərin hər ikisi üçün hesablanmış SHA-1 heş dəyəri tamamilə eynidir:*

`1eacb25ed5970d10f17369635771bc3a17b48ac5`

Bu nümunə sübut edir ki, təcavüzkar rəqəmsal imza prosesində orijinal sənədi onunla eyni heşə malik olan saxta sənədlə əvəz edə bilər, çünki sistem hər iki sənədi eyni identifikatorla tanıyacaqdır.

SHAttered hücumunun əhəmiyyəti:

- İlk dəfə SHA-1 üçün tam praktik toqquşmanın mümkünlüyü sübut edildi.
- Hücumun bulud hesablama resursları ilə xərci təxminən \$110,000 təşkil etmişdir.
- Git və SVN kimi versiya idarəetmə sistemlərinin strukturuna bu zəiflik təsir etdi.
- Sertifikat Mərkəzləri (CA) SHA-1 əsaslı rəqəmsal imzaların və sertifikatların istifadəsini dərhal dayandırdılar.

4.5 SHA-1-in hazırkı vəziyyəti

SHAttered hücumundan sonra SHA-1 alqoritmi bütün kritik infrastrukturda **etibarsız** hesab edilir:

- **NIST:** 2011-ci ildən etibarən rəqəmsal imzalarda SHA-1-in istifadəsini rəsmən tövsiyə etmir.
- **CA/Browser Forum:** 2017-ci ildən bəri ictimai etibarlı SSL sertifikatlarında SHA-1-in istifadəsi qadağan edilmişdir.
- **Müasir Brauzerlər:** Chrome, Firefox və Safari SHA-1 istifadə edən sertifikatları "təhlükəli" kimi işarələyir və ya bloklayır.
- **Git versiya idarəetmə sistemi:** Git daxili identifikatorlar üçün hələ də SHA-1-dən istifadə etsə də, toqquşmaların qarşısını almaq üçün xüsusi yoxlama mexanizmləri tətbiq olunur.
- **Ümumi tövsiyə:** SHA-1 yalnız köhnə sistemlərlə geriye uyğunluq (legacy support) məqsədilə və təhlükəsizlik tələb olunmayan qeyri-kritik hallarda istifadə edilə bilər.

5 SHA-2 ailəsi

5.1 SHA-2-nin tarixi və yaranması

SHA-2 (*Secure Hash Algorithm 2*) — NSA tərəfindən hazırlanmış və 2001-ci ildə NIST FIPS PUB 180-2 standartı ilə rəsmiləşdirilmiş heş funksiyaları ailəsidir. Bu ailə SHA-1 alqoritmində müşahidə olunan struktur zəifliklərini aradan qaldırmaq və MD5-ə qarşı tətbiq edilən hücum metodlarına qarşı daha yüksək davamlılıq nümayiş etdirmək üçün dizayn edilmişdir.

5.2 SHA-2 variantları

SHA-2 ailəsi çıxış uzunluğu və blok ölçüsünə görə fərqlənən 6 əsas variantdan ibarətdir:

Alqoritm	Çıxış uzunluğu	Daxili vəziyyət	Blok ölçüsü
SHA-224	224-bit	256-bit	512-bit
SHA-256	256-bit	256-bit	512-bit
SHA-384	384-bit	512-bit	1024-bit
SHA-512	512-bit	512-bit	1024-bit
SHA-512/224	224-bit	512-bit	1024-bit
SHA-512/256	256-bit	512-bit	1024-bit

Table 2: SHA-2 ailəsinin variantları

5.3 SHA-256-nın quruluşu

SHA-256 bu ailənin ən geniş tətbiq olunan variantıdır. Onun əməliyyat strukturu aşağıdakı kimidir:

- **Çıxış uzunluğu:** 256-bit (8×32 -bit söz: A, B, C, D, E, F, G, H).

- **Blok ölçüsü:** 512-bit (16×32 -bit söz).
- **Daxili vəziyyət:** 8×32 -bit söz.
- **Raund sayı:** 64 raund.

Hər bir raundda daxili vəziyyət registrləri aşağıdakı tənliklər sistemi ilə yenilənir:

$$\begin{aligned} T_1 &= H + \Sigma_1(E) + Ch(E, F, G) + K_t + W_t \\ T_2 &= \Sigma_0(A) + Maj(A, B, C) \\ H &= G; \quad G = F; \quad F = E; \quad E = D + T_1 \\ D &= C; \quad C = B; \quad B = A; \quad A = T_1 + T_2 \end{aligned}$$

Raund daxilində istifadə olunan köməkçi funksiyalar:

$$\begin{aligned} Ch(x, y, z) &= (x \wedge y) \oplus (\neg x \wedge z) \\ Maj(x, y, z) &= (x \wedge y) \oplus (x \wedge z) \oplus (y \wedge z) \\ \Sigma_0(x) &= ROTR_2(x) \oplus ROTL_{13}(x) \oplus ROTL_{22}(x) \\ \Sigma_1(x) &= ROTR_6(x) \oplus ROTR_{11}(x) \oplus ROTR_{25}(x) \end{aligned}$$

Mesaj Genişləndirilməsi (W_t): 512-bitlik ilkin blok 64 ədəd 32-bitlik sözə genişləndirilir:

$$W_t = \begin{cases} M_t & 0 \leq t \leq 15 \\ \sigma_1(W_{t-2}) + W_{t-7} + \sigma_0(W_{t-15}) + W_{t-16} & 16 \leq t \leq 63 \end{cases}$$

Burada $\sigma_0(x)$ və $\sigma_1(x)$ funksiyaları aşağıdakı kimidir:

$$\begin{aligned} \sigma_0(x) &= ROTR_7(x) \oplus ROTR_{18}(x) \oplus SHR_3(x) \\ \sigma_1(x) &= ROTR_{17}(x) \oplus ROTR_{19}(x) \oplus SHR_{10}(x) \end{aligned}$$

K_t sabitləri ilk 64 sadə ədədin kvadrat kökünün kəsr hissəsindən təyin edilmişdir.

5.4 SHA-2-nin təhlükəsizliyi

SHA-2 ailəsi hazırda kriptografik baxımdan **təhlükəsiz** hesab edilir və sənaye standartı olaraq geniş istifadə olunur. Onun təhlükəsizlik göstəriciləri aşağıdakı kimidir:

- **Ön görüntü (Pre-image) dayanıqlılığı:** 2^n (məsələn, SHA-256 üçün 2^{256} əməliyyat).
- **İkinci ön görüntü dayanıqlılığı:** 2^n mürəkkəblik tələb edir.
- **Toqquşma (Collision) dayanıqlılığı:** Ad günü paradoksuna əsasən $2^{n/2}$ mürəkkəblik (SHA-256 üçün 2^{128}).
- **Uzunluq genişləndirmə (Length extension) hücumu:** SHA-2 Merkl-Damqord quruluşuna əsaslandığı üçün bu spesifik hücum növünə qarşı həssasdır. Bu hücumun qarşısını almaq üçün HMAC strukturlarından və ya SHA-512/256 variantından istifadə edilir.

SHA-2 alqoritminin tam versiyasına qarşı indiyə qədər heç bir praktik toqquşma və ya sındırılma nümayiş etdirilməmişdir. Mövcud nəzəri hücumlar yalnız raund sayı azaldılmış versiyaları əhatə edir:

- **2008-ci il:** SHA-256-nın 31 raundluq (tam 64 raunddan) versiyasına qarşı nəzəri hücum təsvir edilmişdir.
- **2011-ci il:** SHA-512-nin 24 raundluq (tam 80 raunddan) versiyasına qarşı nəzəri hücum nümayiş etdirilmişdir.
- **2016-cı il:** SHA-256-nın 28 raundluq versiyasına qarşı təkmilləşdirilmiş nəzəri hücum metodikası təklif edilmişdir.

Nəzəri hücumların raund sayının yarısından belə az hissəsini əhatə etməsi SHA-2-nin yüksək təhlükəsizlik marjasına malik olduğunu sübut edir.

6 Heş funksiyalarının müqayisəsi

6.1 Təhlükəsizlik müqayisəsi

Xüsusiyyət	MD5	SHA-1	SHA-256	SHA-512
Çıxış uzunluğu	128-bit	160-bit	256-bit	512-bit
Ön görüntü dayanıqlılığı	2^{128}	2^{160}	2^{256}	2^{512}
Toqquşma dayanıqlılığı (nəzəri)	2^{64}	2^{80}	2^{128}	2^{256}
Praktik toqquşma?	Bəli (2004)	Bəli (2017)	Xeyr	Xeyr
Uzunluq genişləndirmə hücumu	Həssas	Həssas	Həssas	Həssas
Hazırkı status	Sındırılmış	Etibarsız	Təhlükəsiz	Təhlükəsiz

6.2 Performans müqayisəsi

Performans testləri göstərir ki, alqoritmin mürəkkəbliyi artdıqca proqram təminatı səviyyəsində sürət azalır, lakin aparat sürətləndiriciləri (Hardware Extensions) bu fərqi aradan qaldırır:

Alqoritm	Software (Sürət)	Hardware (Intel/AMD SHA-NI)	Yaddaş (State)
MD5	450–500 MB/s	Dəstəklənmir	128-bit
SHA-1	350–400 MB/s	1500+ MB/s	160-bit
SHA-256	180–210 MB/s	1000+ MB/s	256-bit
SHA-512	250–280 MB/s	Adətən yoxdur*	512-bit

Table 4: Performans müqayisəsi (MB/s göstəriciləri təxminidir və arxitekturdan asılıdır)

- **SHA-1 Aparat təminatı (Hardware):** Müasir prosessorlarda (Intel SHA-NI dəstəyi ilə) SHA-1 aparat səviyyəsində sürətləndirilir və proqram səviyyəsindəki MD5-dən qat-qat sürətli olur.

- **SHA-512 Sürəti:** 64-bitlik arxitekturalarda SHA-512-nin SHA-256-dan daha sürətli olmasının səbəbi onun 64-bitlik hesablamalardan istifadə etməsidir (eyni anda daha çox məlumat emal edilir).
- **Yaddaş:** "Aşağı/Orta/Yüksək" yerinə daxili vəziyyətin (internal state) ölçüsünü bitlərlə göstərmək daha akademik yanaşmadır.

6.3 Tətbiq sahələrinə görə seçim

Müasir sistemlərdə heş funksiyasının seçilməsi həmin tətbiqin təhlükəsizlik tələblərindən və aparat resurslarından asılıdır:

- **Kriptovalyutalar (Bitcoin):** SHA-256 (əsasən ikili SHA-256 əməliyyatı tətbiq olunur).
- **TLS/SSL sertifikatları:** SHA-256 (müasir standartlar üçün minimum tələb), SHA-384 və SHA-512.
- **Şəbəkə protokolları (SSH, IPsec):** SHA-256, SHA-384 və SHA-512.
- **Elektron poçt təhlükəsizliyi (GPG/PGP):** SHA-256 və SHA-512.
- **Versiya idarəetmə sistemləri (Git):** SHA-1 (tarixi olaraq istifadə olunur, lakin toqquşma riskinə görə SHA-256-ya keçid prosesi davam edir).
- **Parolların saxlanması:** SHA-256/512 + duz (*salt*) istifadəsi ilə yanaşı, "brute-force" hücumlarına qarşı dayanıqlı yavaş heş alqoritmləri (*bcrypt*, *scrypt*, *Argon2*) tövsiyə olunur.
- **Fayl bütövlüyünün yoxlanılması:** SHA-256 və SHA-512.
- **Mesaj autentifikasiyası (HMAC):** HMAC-SHA-256 və HMAC-SHA-512.

Kritik sistemlərdə artıq MD5 və SHA-1 funksiyalarından istifadə edilməməli, onların yerinə SHA-2 ailəsi və ya daha müasir SHA-3 standartları tətbiq olunmalıdır.

7 Praktik tövsiyələr

Heş funksiyalarının seçimi üçün əsas tövsiyələr

- **MD5-dən qaçın:** Təhlükəsizlik tələb edən heç bir infrastrukturda istifadə etməyin. Bu alqoritm yalnız qeyri-kriptoqrafik tətbiqlərdə (məsələn, sürətli checksum yoxlaması və ya qeyri-tənqidi indeksləşdirmə) istifadə oluna bilər.
- **SHA-1 istifadəsini dayandırın:** Mövcud sistemlərdə SHA-1-i təcili olaraq SHA-2 və ya SHA-3 ilə əvəz edin. Unutmayın ki, müasir brauzerlər və Sertifikat Mərkəzləri SHA-1 əsaslı SSL sertifikatlarını artıq qəbul etmir.
- **SHA-256 standart seçimdir:** SHA-256 alqoritmi təxminən 128-bit toqquşma dayanıqlığı və 256-bit ön-görüntü (*pre-image*) dayanıqlığı təmin edir. Bu səviyyə əksər müasir veb və proqram tətbiqləri üçün kifayətdir.
- **SHA-512 yüksək təhlükəsizlik üçün:** Daha yüksək təhlükəsizlik marjası tələb edən sistemlərdə və ya 64-bitlik arxitekturalarda performans üstünlüyü qazanmaq üçün SHA-512 variantına üstünlük verin.
- **Uzunluq genişləndirmə hücumundan qorunma:** Merkl-Damqord quruluşuna xas olan zəifliklərdən qaçmaq üçün $H(K \parallel M)$ tipli sadə birləşmələr əvəzinə, rəsmən sənədləşdirilmiş **HMAC** (*Hash-based Message Authentication Code*) konstruksiyasından istifadə edin.
- **Parol təhlükəsizliyi:** SHA-2 ailəsi təkbəşinə parol saxlanması üçün tövsiyə edilmir. Parolların "brute-force" və göy qurşağı cədvəlləri (*rainbow tables*) ilə sındırılmasının qarşısını almaq üçün **PBKDF2**, **bcrypt**, **scrypt** və ya müasir standart olan **Argon2** kimi yavaş, yaddaş tutumlu funksiyalardan istifadə edilməlidir.
- **Kriptoqrafik çeviklik (Cryptographic Agility):** Uzunmüddətli layihələrdə sisteminizi elə dizayn edin ki, gələcəkdə alqoritmə zəiflik tapılırsa, kod bazasını kökündən dəyişmədən başqa bir heş funksiyasına (məsələn, SHA-3) asanlıqla keçid edə bilərsiniz.

8 Nümunə məsələlər və çalışmalar

Çalışma 8.1 (1). MD5-in çıxış uzunluğu 128-bitdir. Ad günü paradoksuna əsasən, MD5-də toqquşma tapmaq üçün nəzəri mürəkkəblik nədir? Praktik mürəkkəblik nə qədər azaldılıb?

Çalışma 8.2 (2). SHA-1 üçün SHAttered hücumunun əhəmiyyətini izah edin. Bu hücum Git kimi versiya idarəetmə sistemlərinə necə təsir edir?

Çalışma 8.3 (3). SHA-256 və SHA-512 arasında əsas fərqlər nələrdir? Hansı hallarda SHA-512 SHA-256-dan üstündür?

Çalışma 8.4 (4). MD5 və SHA-1-in uzunluq genişləndirmə hücumuna qarşı həssas olmasının səbəbi nədir? Bu problemi necə həll etmək olar?

Çalışma 8.5 (5). Bir serverdə köhnə sistemlə uyğunluq üçün MD5 istifadə olunur. Bu serverin təhlükəsizlik risklərini qiymətləndirin və keçid strategiyası təklif edin.

Çalışma 8.6 (6). *SHA-256-nın daxili quruluşunda istifadə olunan C_h və M_a funksiyalarının məqsədi nədir?*

Çalışma 8.7 (7). *Bitcoin-də niyə ikili SHA-256 ($SHA-256(SHA-256(x))$) istifadə olunur?*

Çalışma 8.8 (8). *2026-cı ildə yeni bir proqram sistemi qurursunuz. Hansı heş funksiyasını seçərdiniz və niyə?*

9 Çalışmaların həlli

1. MD5-də nəzəri toqquşma tapmaq mürəkkəbliyi $2^{n/2}$ düsturuna əsasən 2^{64} əməliyyatdır. Wang və digərlərinin tədqiqatları bu mürəkkəbliyi 2^{39} əməliyyata endirmişdir. Hazırda MD5 üçün praktik toqquşma tapmaq saniyələr ərzində mümkündür.
2. SHattered hücumu SHA-1 üçün ilk praktik toqquşmanı (2^{63} mürəkkəbliklə) nümayiş etdirmişdir. Git SHA-1-dən istifadə etsə də, Git obyektlərinə tip və uzunluq məlumatı (header) əlavə olunduğu üçün birbaşa PDF toqquşmaları Git-in bütövlüyünü dərhal pozmur. Lakin təhlükəsizlik nəminə Git-in SHA-256-ya keçid prosesi planlanmışdır.
3. SHA-256 32-bitlik, SHA-512 isə 64-bitlik sözlərlə işləyir. SHA-512 daha böyük daxili vəziyyətə (512-bit) malikdir. 64-bitlik müasir prosessorlarda SHA-512 hər dövrdə daha çox məlumat emal etdiyi üçün SHA-256-dan daha yüksək performans göstərə bilər.
4. Bu funksiyalar Merkl-Damqord quruluşuna əsaslanır və heş çıxışı funksiyanın son daxili vəziyyətini (state) təmsil edir. Hücumçu bu vəziyyətdən başlayaraq mesajın sonuna yeni məlumatlar əlavə edə bilər. Həll yolu olaraq $H(K \parallel M)$ yerinə HMAC strukturundan istifadə edilməlidir.
5. MD5 istifadəsi serveri rəqəmsal imzaların saxtalaşdırılması riskinə məruz qoyur. Keçid üçün: 1) Funksionallığı SHA-256-ya miqrasiya etmək; 2) Müvəqqəti olaraq həm MD5, həm SHA-256 heşlərini paralel saxlamaq; 3) Müştəri tərəfi yeniləmələri tətbiq edərək MD5 dəstəyini tamamilə ləğv etmək tövsiyə olunur.
6. $Ch(x, y, z)$ funksiyası x bitinə əsasən y və ya z bitini seçən şərti seçim funksiyasıdır. $Maj(x, y, z)$ funksiyası isə üç giriş bitindən əksəriyyət təşkil edən (2 və ya 3 bit eynidirsə) qaytarır. Bu funksiyalar alqoritmin qeyri-xəttiliyini təmin edir.
7. Bitcoin-də ikili SHA-256 (Double SHA-256) istifadəsi əsasən uzunluq genişləndirmə hücumlarından (length extension attacks) qorunmaq və alqoritmin təhlükəsizlik ehtiyatını (margin) artırmaq məqsədi daşıyır.
8. 2026-cı ildə yeni sistemlər üçün **SHA-256** və ya **SHA-512** standart seçimdir. 128-bitlik toqquşma dayanıqlığı müasir tələblərə tam cavab verir. Yüksək kritiklikli və uzunmüddətli sistemlər üçün isə SHA-2-dən fərqli quruluşa malik olan **SHA-3** (Keccak) tövsiyə olunur.

10 Xülasə

Bu mühazirədə kriptografik heş funksiyalarının inkişaf tarixini və müasir vəziyyətini əhatə edən aşağıdakı əsas anlayışları öyrəndik:

- **MD5:** Ron Rivest tərəfindən 1991-ci ildə hazırlanmış 128-bitlik heş funksiyasıdır. 2004-cü ildə tam toqquşma aşkar edildikdən sonra hal-hazırda **tamamilə sındırılmış** hesab edilir və təhlükəsizlik tətbiqlərində istifadəsi qadağandır.
- **SHA-1:** NSA tərəfindən 1995-ci ildə təqdim edilmiş 160-bitlik heş funksiyasıdır. 2017-ci ildə SHattered hücumu ilə ilk praktik toqquşma nümayiş etdirilmişdir. Hal-hazırda **etibarsız** hesab edilir və müasir standartlardan çıxarılmışdır.

- **SHA-2:** NSA tərəfindən 2001-ci ildə hazırlanmış və daxilində SHA-224, SHA-256, SHA-384, SHA-512 kimi variantları birləşdirən heş funksiyaları ailəsidir. Hal-hazırda sənaye standartı olaraq **təhlükəsiz** qəbul edilir.
- **SHA-256:** SHA-2 ailəsinin ən geniş tətbiq olunan variantıdır. 256-bitlik çıxış və 64 raundluq strukturu ilə Bitcoin, TLS/SSL və SSH kimi kritik sistemlərin əsasını təşkil edir.
- **SHA-512:** 64-bitlik arxitekturalar üçün optimallaşdırılmış, 512-bitlik çıxış və 80 raundluq struktura malik SHA-2 variantıdır. Yüksək təhlükəsizlik marjası və performans üstünlüyü ilə seçilir.

Əsas nəticə: Kriptografik təhlükəsizliyin təmin edilməsi üçün MD5 və SHA-1 kimi köhnəlmiş funksiyalardan imtina edilməli, onların yerinə **SHA-256** və ya **SHA-512** tətbiq olunmalıdır. Gələcək nəsillər üçün isə fərqli struktura malik olan **SHA-3** standartına keçid nəzərdən keçirilməlidir.

11 Əlavə oxu üçün materiallar

Mövzu ilə daha dərinədən tanış olmaq və tədqiqatların orijinal mənbələrini araşdırmaq üçün aşağıdakı elmi materiallar tövsiyə olunur:

1. **Rivest, R. (1992).** "The MD5 Message-Digest Algorithm" — RFC 1321. MD5 alqoritminin müəllifi tərəfindən təqdim edilmiş orijinal spesifikasiya.
2. **NIST (1995).** "Secure Hash Standard" — FIPS PUB 180-1. SHA-1 alqoritminin rəsmi standartı və texniki təsviri.
3. **NIST (2015).** "Secure Hash Standard (SHS)" — FIPS PUB 180-4. SHA-2 ailəsinin (SHA-224, 256, 384, 512) əhatə edən müasir standart sənədi.
4. **Wang, X. & Yu, H. (2005).** "How to Break MD5 and Other Hash Functions". MD5 və digər heş funksiyalarına qarşı tarixi toqquşma hücumlarını izah edən fundamental tədqiqat.
5. **Stevens, M. et al. (2017).** "The First Collision for Full SHA-1" — SHattered. SHA-1-in praktik olaraq sındırılmasını sübut edən elmi məqalə.
6. **Dang, Q. (2011).** "Updated Security Considerations for the MD5 Message-Digest and the HMAC-MD5 Algorithms" — RFC 6151. MD5-in müasir sistemlərdə istifadəsinin riskləri haqqında yenilənmiş təhlükəsizlik tövsiyələri.

References

NIST. Secure hash standard. Technical Report FIPS PUB 180-1, National Institute of Standards and Technology, April 1995. SHA-1-in rəsmi standartı.

M. Stevens, A. Lenstra, and B. de Weger. Chosen-prefix collisions for md5 and applications. In *International Workshop on Fast Software Encryption (FSE 2009)*, volume 5665 of *Lecture Notes in Computer Science*, pages 322–336. Springer, 2009. doi: 10.1007/978-3-642-03317-9_20.

-
- D. R. Stinson and M. B. Paterson. *Cryptography: Theory and Practice*. CRC Press, Boca Raton, 4th edition, 2018. ISBN: 978-1138197015.
- X. Wang and H. Yu. How to break md5 and other hash functions. *Advances in Cryptology - EUROCRYPT 2005*, 3494:19–35, 2005. doi: 10.1007/11426639_2.